

Tietoturva-auditoinnin suunnitelma – Runko

1. Johdanto

Tässä dokumentissa esitetään tietoturva-auditoinnin suunnitelman runko. Auditoinnin tavoitteena on arvioida pk-yrityksen tietoturvan hallinnolliset käytännöt ja tekninen suojaustaso sekä antaa kehitysehdotuksia. Auditointi perustuu seuraaviin viitekehyksiin: Traficom/Kyberturvallisuuskeskus – Tietoturvaopas pk-yrityksille, ISO/IEC 27001/27002, sekä NIST Cybersecurity Framework.

2. Auditoinnin tavoite

Auditoinnin päätavoitteena tässä työharjoittelussa on oppia ja rakentaa kokonaiskuva pk-yrityksen tietoturva-auditoinnin prosessista. Harjoittelu ei kohdisteta oikeaan yritykseen. Tavoitteena on perehtyä hallinnollisiin ja teknisiin tietoturvakäytäntöihin sekä muodostaa vaiheistettu palvelumalli, jota voidaan soveltaa pk-yrityksen tietoturvan arviointiin. Käytännön osuudessa rakennetaan POC-ympäristö, jossa testataan avoimen lähdekoodin työkaluja ja dokumentoidaan prosessi oppimisen ja raportoinnin tueksi.

3. Rajaus

Auditoinnin rajaus määrittelee, mitä osa-alueita arvioidaan ja mitä jätetään ulkopuolelle.

Mukana: Hallinnolliset käytännöt, IT-infrastruktuuri (verkko, palvelimet), salasanakäytännöt.

Ei mukana: Syvä penetraatiotestaus, tuotantojärjestelmien kuormitustestaus, fyysisen ympäristön tarkastus, henkilöstön koulutus, varmuuskopiointi.

4. Menetelmät

- Dokumenttien ja ohjeistusten läpikäynti
- Haastattelut (menetelmä kuuluu tietoturva-auditointeihin, mutta sitä ei toteutettu tässä harjoituksessa)
- Tekninen testaus POC-ympäristössä (Nmap, OpenVAS, Lynis)

5. Aikataulu ja vaiheet

Vaiheistus perustuu GitHub-projektitauluun. Alustava aikataulu voisi olla:

- Vaihe 1: Hallinnollinen osuus (viitekehysten kartoitus, checklist, suunnitelma)
- Vaihe 2: Teknisen osuuden suunnittelu ja työkalujen testaus
- Vaihe 3: POC-ympäristön rakentaminen
- Vaihe 4: Testaus ja tulosten keruu
- Vaihe 5: Analyysi ja suositukset
- Vaihe 6: Loppuraportti